

Security+ 4.3 · Vulnerability Scanning

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.3** —
Vulnerability Scanning (7:45) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Vulnerability scanning uses automated tools (Nessus, Qualys, OpenVAS) to compare systems against known CVEs. SAST analyzes source code statically, while fuzzing feeds malformed input to trigger crashes. Scanners rely on vulnerability feeds for up-to-date CVE data.

High-Yield Core Concepts Tested on Exam

- Vulnerability scan: compares system state against known CVEs
- SAST: static analysis reads source code for flaws
- Fuzzing: sends malformed input to trigger crashes and uncover hidden bugs
- Vulnerability feed: continuously updates scanner with new CVE data
- Scanners identify known vulnerabilities but may miss logic flaws

Exam Tips & Classic Scenarios

- 'automated tool checks for known vulnerabilities' = vulnerability scan
- 'feeds random input to break the application' = fuzzing
- 'analyzes source code without executing it' = SAST

Typical Exam Scenario: A scanner reports that a server is affected by CVE-2023-12345, indicating a vulnerability scan has matched the system against a known CVE.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.3 — Vulnerability Scanning)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **CVE:** Common Vulnerabilities and Exposures: Publicly standardized dictionary of known information security vulnerabilities and exposures.
- **CVSS:** Common Vulnerability Scoring System: Industry standardized 0.0 to 10.0 framework evaluating vulnerability severity (Low, Medium, High, Critical).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. In the CVSS 3.1 system, a vulnerability with a score of 9.8 is classified as:

- A)** Low
- B)** Medium
- C)** High
- D)** Critical

2. A CVE-2024-1234 vulnerability scored CVSS 3.1 as 7.5 (High). What should be done FIRST?

- A)** Apply patch immediately on all servers
- B)** Assess the risk in the context of the specific environment
- C)** Ignore it because it is not critical
- D)** Replace the affected system

3. Corporate scenario (Vulnerability Scanning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'Vuln scan: compares the system against known CVEs'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Vuln scan: compares the system against known CVEs...

4. Corporate scenario (Vulnerability Scanning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'Fuzzing: throws crazy input until it breaks — finds bugs the code doesn't show'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Fuzzing: throws crazy input until it breaks — finds bugs the code doesn't show...
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Vulnerability Scanning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'automated tool checks for known vulnerabilities'=vulnerability scan'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'automated tool checks for known vulnerabilities'=vulnerability scan...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Vulnerability Scanning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'scanner reports that the server has CVE-2023-12345'=vuln scan finding CVE.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'scanner reports that the server has CVE-2023-12345'=vuln scan finding CVE...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Vulnerability Scanning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'Vuln scan: compares the system against known CVEs'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Vuln scan: compares the system against known CVEs...

8. Corporate scenario (Vulnerability Scanning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'Fuzzing: throws crazy input until it breaks — finds bugs the code doesn't show'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Fuzzing: throws crazy input until it breaks — finds bugs the code doesn't show...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Vulnerability Scanning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'automated tool checks for known vulnerabilities' = vulnerability scan. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'automated tool checks for known vulnerabilities' = vulnerability scan.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Vulnerability Scanning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'scanner reports that the server has CVE-2023-12345' = vuln scan finding CVE. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'scanner reports that the server has CVE-2023-12345' = vuln scan finding CVE.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) D — Critical.

✓ **Why it's correct:** In the CVSS 3.1 (Common Vulnerability Scoring System), the base score ranges from 0.0 to 10.0 and is categorized into four ranges: Low (0.1–3.9), Medium (4.0–6.9), High (7.0–8.9), and Critical (9.0–10.0). A vulnerability with a score of 9.8 therefore falls into the Critical range, indicating severe impact and trivial or near-trivial exploitability, with the potential to compromise confidentiality, integrity, and availability massively. CompTIA Security+ requires professionals to interpret these ranges to prioritize remediation.

✗ **Why the others are wrong:**

- *Low:* The Low classification in CVSS 3.1 covers scores from 0.1 to 3.9. Vulnerabilities in this range typically require very specific conditions for exploitation, have limited impact, or require highly privileged local access. A score of 9.8 is far above this range, indicating extreme, non-trivial risk. Associating 9.8 with Low demonstrates a complete misunderstanding of the scale.
- *Medium:* The Medium range in CVSS 3.1 goes from 4.0 to 6.9. Medium vulnerabilities can cause moderate damage, often requiring user interaction or partial exploitation conditions. A score of 9.8 far exceeds this threshold, placing it at the top of the scale. Classifying it as Medium would severely underestimate the urgency of remediation and contradict the standard's own numerical definition.
- *High:* The High range in CVSS 3.1 comprises scores from 7.0 to 8.9. Although it is a serious classification, it is still below the Critical threshold. A 9.8 vulnerability is considered Critical because it typically combines remote attack vectors, low complexity, no required privileges, and high impact on all three security pillars. Therefore, labeling it as High is technically incorrect according to the official CVSS 3.1 specification.

2) B — Assess the risk in the context of the specific environment.

✓ **Why it is correct:** Faced with a vulnerability scoring CVSS 7.5 (High), the first action according to vulnerability management best practices and the CompTIA Security+ syllabus is to assess the risk in the specific context of the environment. This means considering the criticality of the affected asset, network exposure, existence of compensating controls, likelihood of real exploitation (e.g., if there is a public exploit or threat activity), and business impact. Only after this contextual analysis is the priority and remediation strategy decided, which may include immediate patching, temporary mitigation, or risk acceptance. The CVSS score is a generic metric and does not replace organizational risk assessment.

✗ **Why the others are wrong:**

- *Apply patch immediately on all servers:* Applying patches immediately on all servers without prior assessment is a reckless approach. Patches can introduce regressions, incompatibilities, or downtime for critical services, and require maintenance windows and testing. Change management and contextual risk assessment are mandatory before any large-scale deployment. Haste can cause more damage than the vulnerability itself, especially if the asset is not exposed or if effective mitigations exist.
- *Ignore it because it is not critical:* Ignoring a vulnerability scoring 7.5 (High) because it is not Critical is a serious prioritization error. The High range indicates significant risk, with potential to seriously compromise the environment. Even if not 9.0+, a High vulnerability can be exploited by attackers to gain initial access, escalate privileges, or cause denial of service. The decision not to act must be based on documented risk analysis, not on a simplistic classification that dismisses everything below Critical.
- *Replace the affected system:* Replacing the affected system is an extreme, costly, and often

infeasible measure in the short term. System replacement involves planning, budgeting, data migration, and testing, and is not an immediate response to a vulnerability. Moreover, the vulnerability can be fixed with a patch or mitigation, making replacement unnecessary. The first action should always be contextual assessment to then decide the proportional response, which is rarely a complete system swap.

3) D — Implement the corresponding solution: Vuln scan: compares the system against known CVEs....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Scanning): Vuln scan: compares the system against known CVEs. Vulnerability scanners identify known vulnerabilities by comparing system configurations and software versions against CVE databases.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) C — Implement the corresponding solution: Fuzzing: throws crazy input until it breaks — finds bugs the code doesn't show....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Scanning): Fuzzing: throws crazy input until it breaks — finds bugs the code doesn't show.

✗ Why the others are wrong:

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) A — Implement the corresponding solution: 'automated tool checks for known vulnerabilities'=vulnerability scan....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Scanning): 'automated tool checks for known vulnerabilities'=vulnerability scan.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) B — Implement the corresponding solution: 'scanner reports that the server has CVE-2023-12345'=vuln scan finding CVE....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Scanning): 'scanner reports that the server has CVE-2023-12345'=vuln scan finding CVE.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: Vuln scan: compares the system against known CVEs....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Scanning): Vuln scan: compares the system against known CVEs. This correctly describes the purpose of vulnerability scanning, which identifies known vulnerabilities by comparing system configurations and software versions against databases like the Common Vulnerabilities and Exposures (CVE) list.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) A — Implement the corresponding solution: Fuzzing: throws crazy input until it breaks — finds bugs the code doesn't show....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Scanning): Fuzzing: throws crazy input until it breaks — finds bugs the code doesn't show. Fuzzing is a dynamic testing technique that feeds random or malformed inputs to a program to uncover vulnerabilities such as buffer overflows, input validation errors, and crashes that may not be evident through static analysis.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: 'automated tool checks for known vulnerabilities' = vulnerability scan..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Scanning): 'automated tool checks for known vulnerabilities' = vulnerability scan. A vulnerability scan uses automated tooling to enumerate systems and compare detected software/configuration against known CVE signatures and misconfiguration databases.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) A — Implement the corresponding solution: 'scanner reports that the server has CVE-2023-12345' = vuln scan finding CVE..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Scanning): 'scanner reports that the server has CVE-2023-12345' = vuln scan finding CVE. A vulnerability scanner identifies known vulnerabilities, often referencing CVEs, to help prioritize remediation.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

